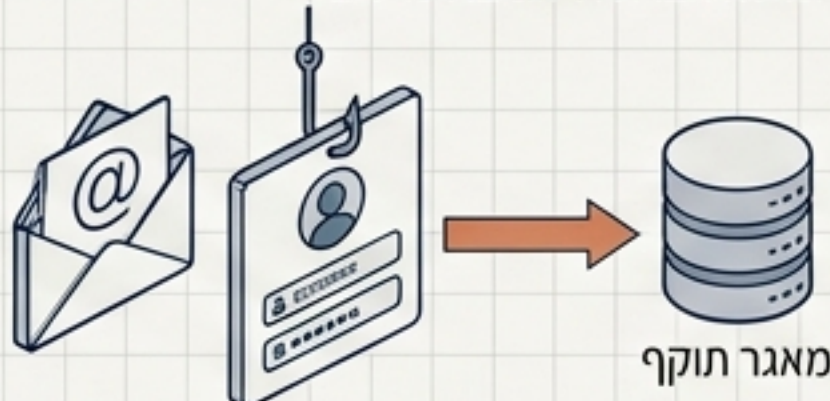


# הארכיטקטורה של גניבת סיסמאות

## 6 וקטורי תקיפה ופרוטוקול ההגנה הארגוני

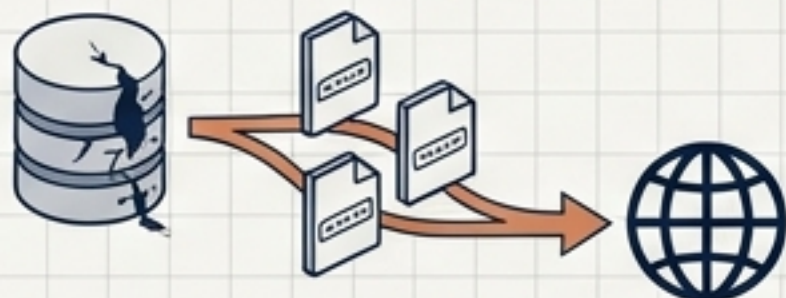
### פישנינג (Phishing)

הנדסה חברתית לגניבת פרטים



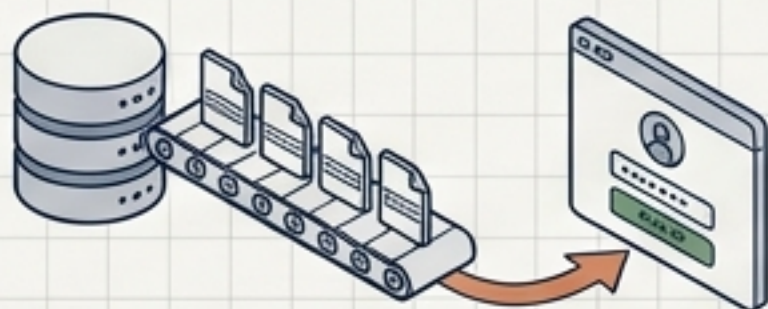
### דליפת מידע (Data Breach)

חשיפת סיסמאות ממאגרים שנפרצו



### Credential Stuffing

שימוש בסיסמאות גנובות באתרי צד ג'



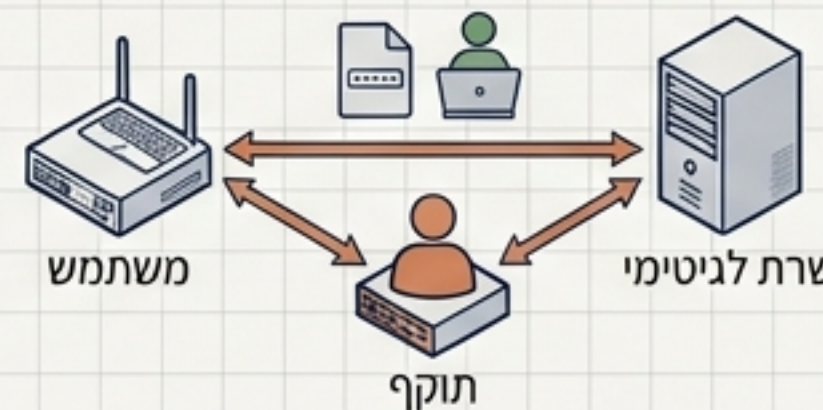
### התקפת כוח גס (Brute Force)

ניחוש סיסמאות אוטומטי

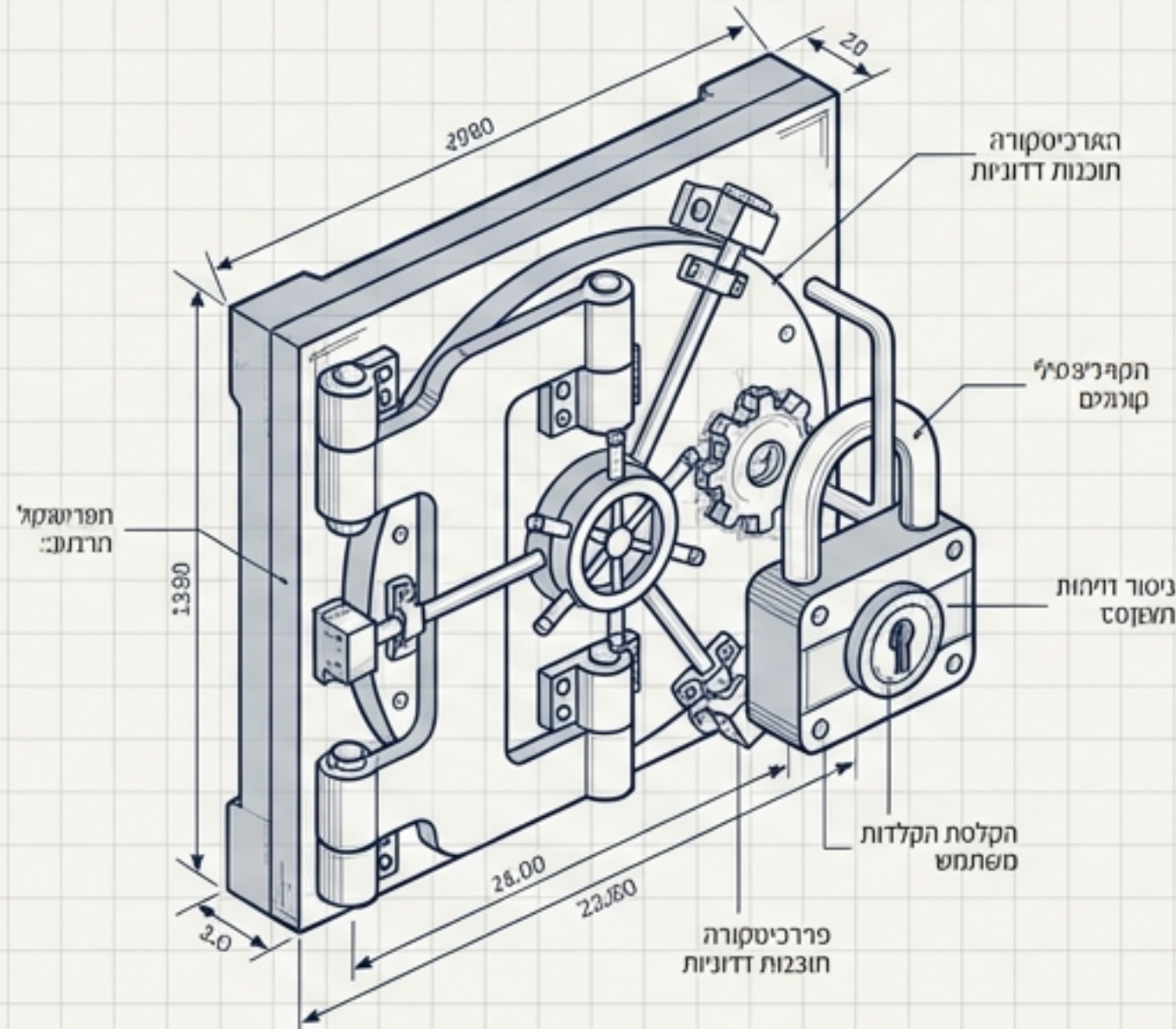


### Man-in-the-Middle (MitM)

יירוט תקשורת בין המשתמש לשרת



הצפת מידע רגיש  
הצוה מידה רגיש



### פרוטוקול ההגנה הארגוני

אימות  
דו-שלבי  
(2FA/MFA)



מנהל  
סיסמאות  
ארגוני



הדרכת  
מודעות  
עובדים





# פרדוקס קו ההגנה



סיסמאות הן קו ההגנה הראשון  
והמרכזי נגד מתקפות סייבר.

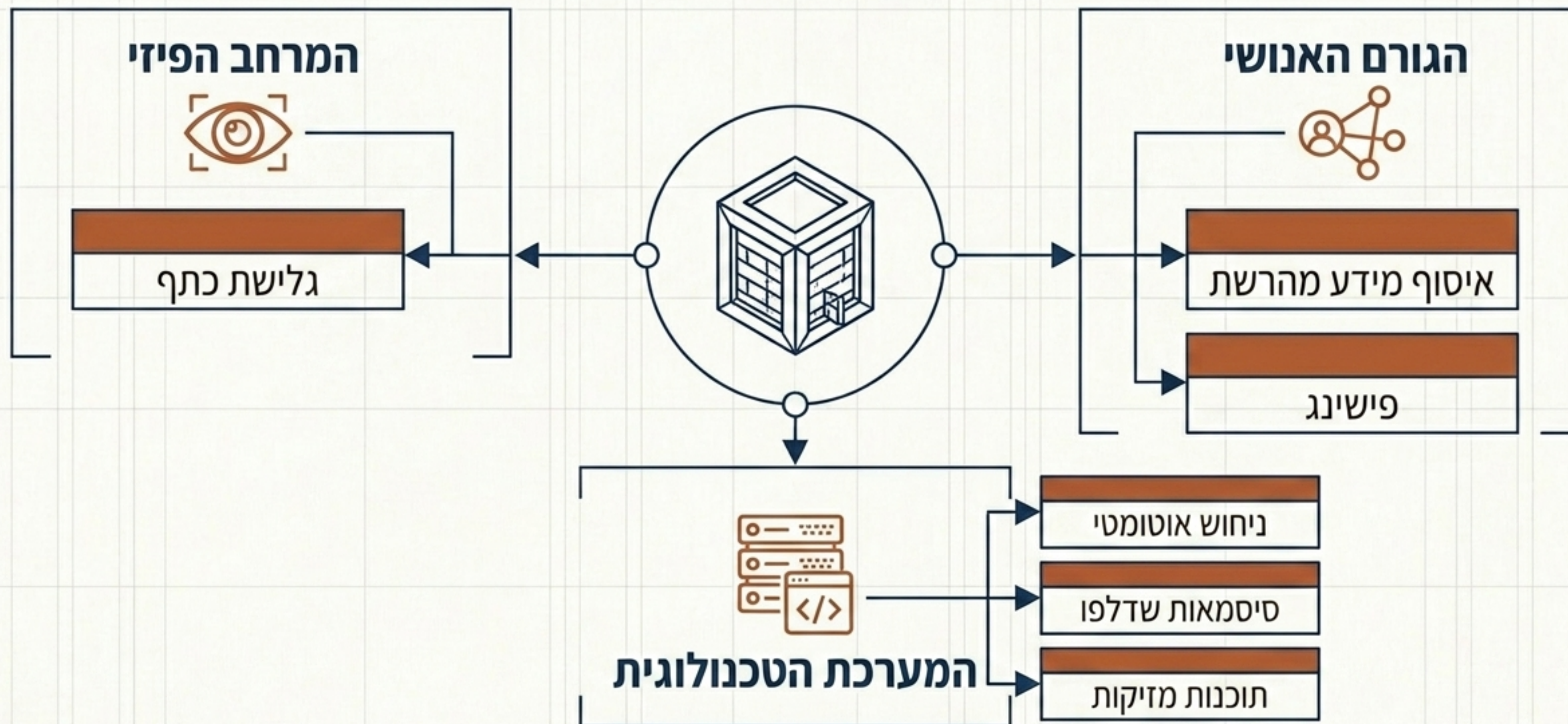


הן גם אחת החוליות **החלשות** ביותר.  
להאקרים יש ארסנל שיטות לעקוף אותן.

**המטרה שלנו: להכיר את מנגנוני התקיפה ולנטרל אותם לפני שהם חודרים לארגון.**

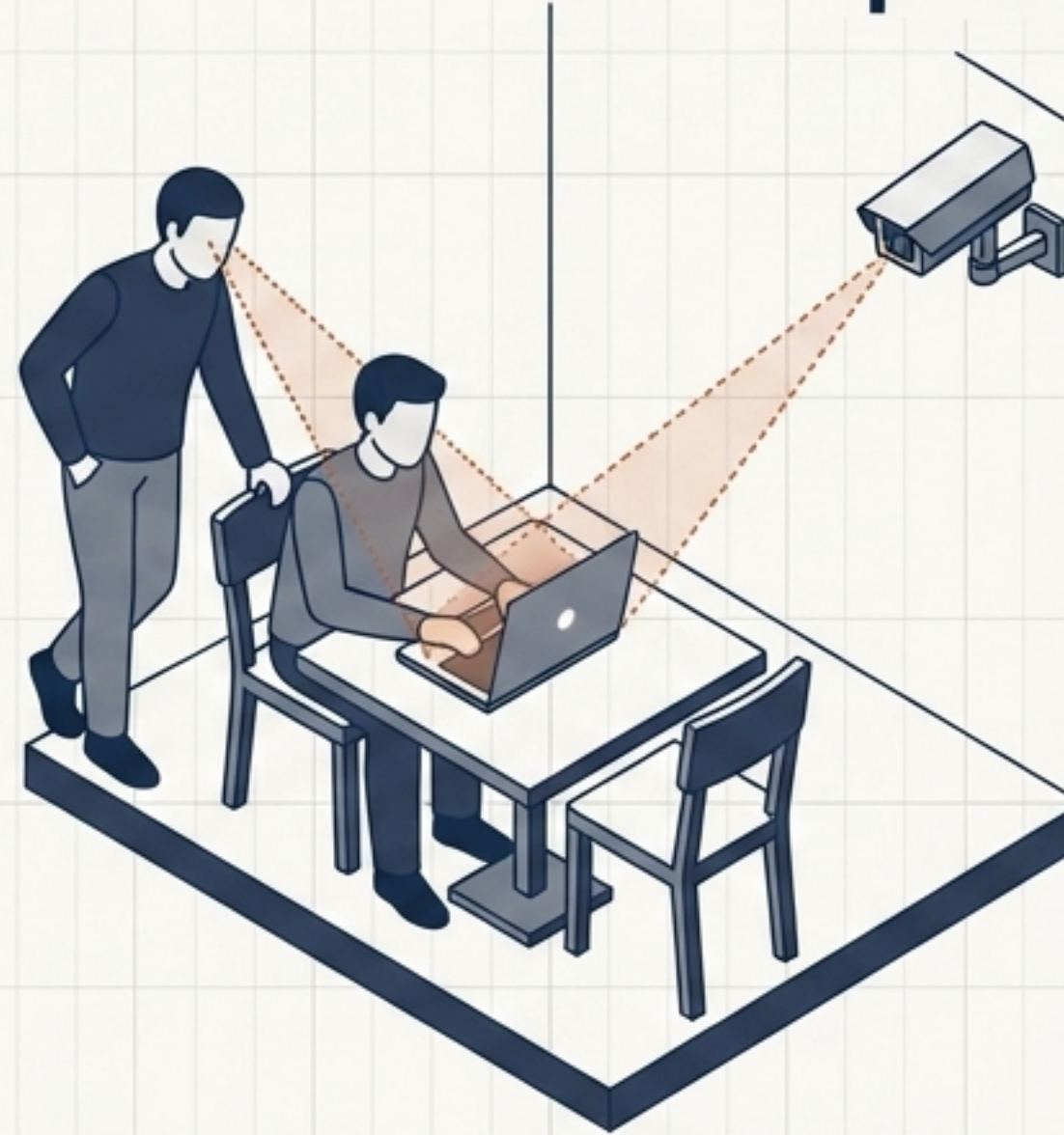


# מפת וקטורי התקיפה





# וקטור 1: המרחב הפיזי | גלישת כתר



| פרוטוקול הגנה  | נקודת התורפה        | → מנגנון התקיפה                                                                               |
|-----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|
| <b>ערנות סביבתית מלאה.</b><br>הימנעות מהזנת סיסמאות במקומות פומביים חשופים.                         | <b>חוסר מודעות סביבתית.</b><br>הקלדת נתונים רגישים בתורים, בתי קפה או חללים משותפים מבלי להסתיר את המסך. | האקר מציץ מעבר לכתף במקום פומבי, במשרד, או משתמש בצילומי מצלמת אבטחה כדי לקלוט את רצף ההקלדה. |



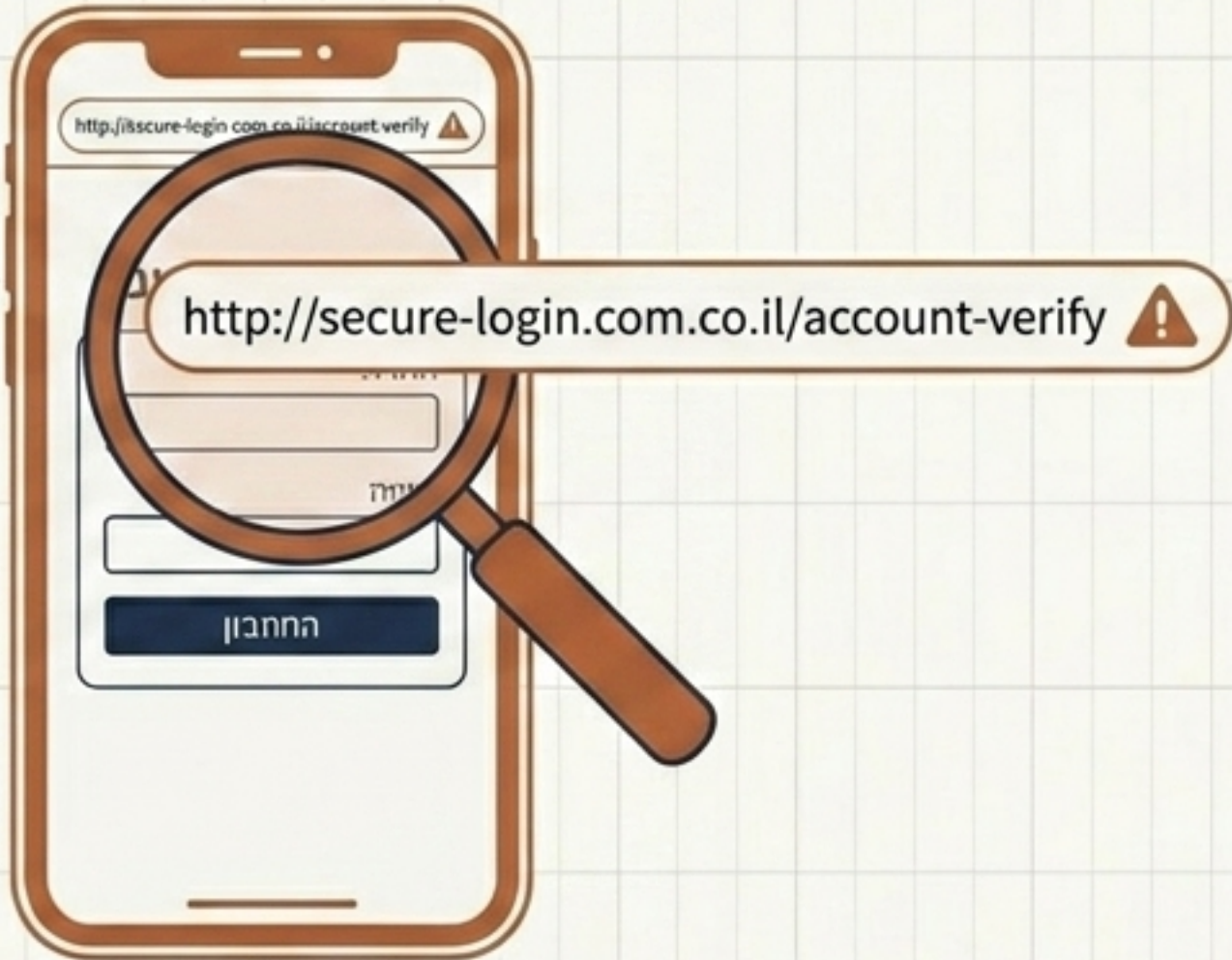
## וקטור 2: הגורם האנושי | איסוף מידע (OSINT)



| פרוטוקול הגנה  | נקודת התורפה  | → מנגנון התקיפה                                                 |
|-----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| הגדרת פרופילים כפרטיים, צמצום חשיפת פרטים אישיים, ואי-שימוש מוחלט בפרטים ביוגרפיים בתוך סיסמאות.    | שימוש בשמות ילדים, בני זוג, חיות מחמד, מספרי טלפון או תאריכי לידה כבסיס לסיסמה.                    | איסוף סימנים מזהים מרשתות חברתיות להרכבת סיסמאות מותאמות אישית. |



וקטור 2: הגורם האנושי | פשינג (דיוג)



| פרוטוקול הגנה   | נקודת התורפה  | → מנגנון התקיפה                                                                   |
|------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------|
| לעולם אין להזין פרטים דרך קישור. יש להיכנס ישירות לאפליקציה או לאתר הרשמי ולבדוק את סטטוס החשבון שם. | כניסה ללחץ פסיכולוגי ולחיצה אוטומטית על קישורים בהודעות SMS או מייל ללא אימות המקור.               | הודעות מתחזות המייצרות פאניקה (למשל: חשבון ננעל) ודורשות התחברות מחדשת דרך קישור. |



# וקטור 3: המערכת | ניחוש אוטומטי (Brute Force)



ניחוש פשוט

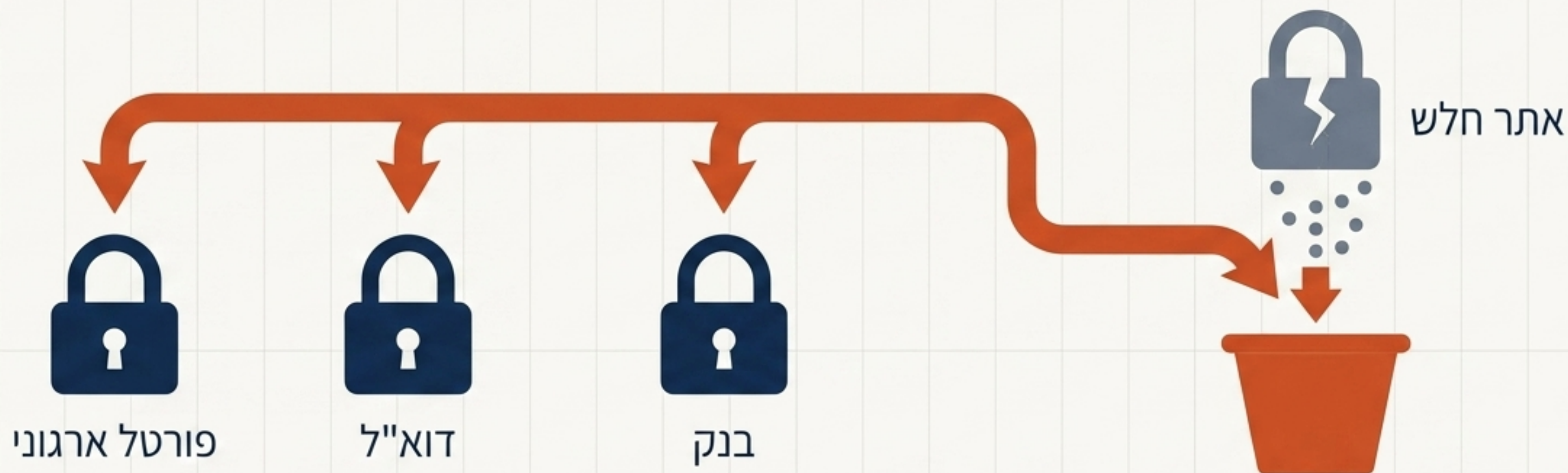


מערכת הגנה חזקה

| פרוטוקול הגנה  | נקודת התורפה  | → מנגנון התקיפה                                                      |
|-----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------|----------------------------------------------------------------------|
| יצירת סיסמאות ארוכות המשלבות אותיות ומספרים שאינן מבוססות על רצפים הגיוניים.                        | שימוש בסיסמאות נפוצות, קצרות, וקלות לניחוש כמו מספרים עוקבים או מילים מילוניות.                    | תוכנות תקיפה המריצות אלפי מילים ושילובים בדקה באופן אוטומטי לחלוטין. |



# וקטור 3: המערכת | שימוש בסיסמאות שדלפו



## מנגנון התקיפה

האקרים פורצים לאתרים בעלי אבטחה לקויה, גונבים את מאגר המשתמשים, ומנסים את אותן סיסמאות באתרים חשובים.



## נקודת התורפה

מיחזור של אותה סיסמה למספר פלטפורמות שונות מטעמי נוחות.



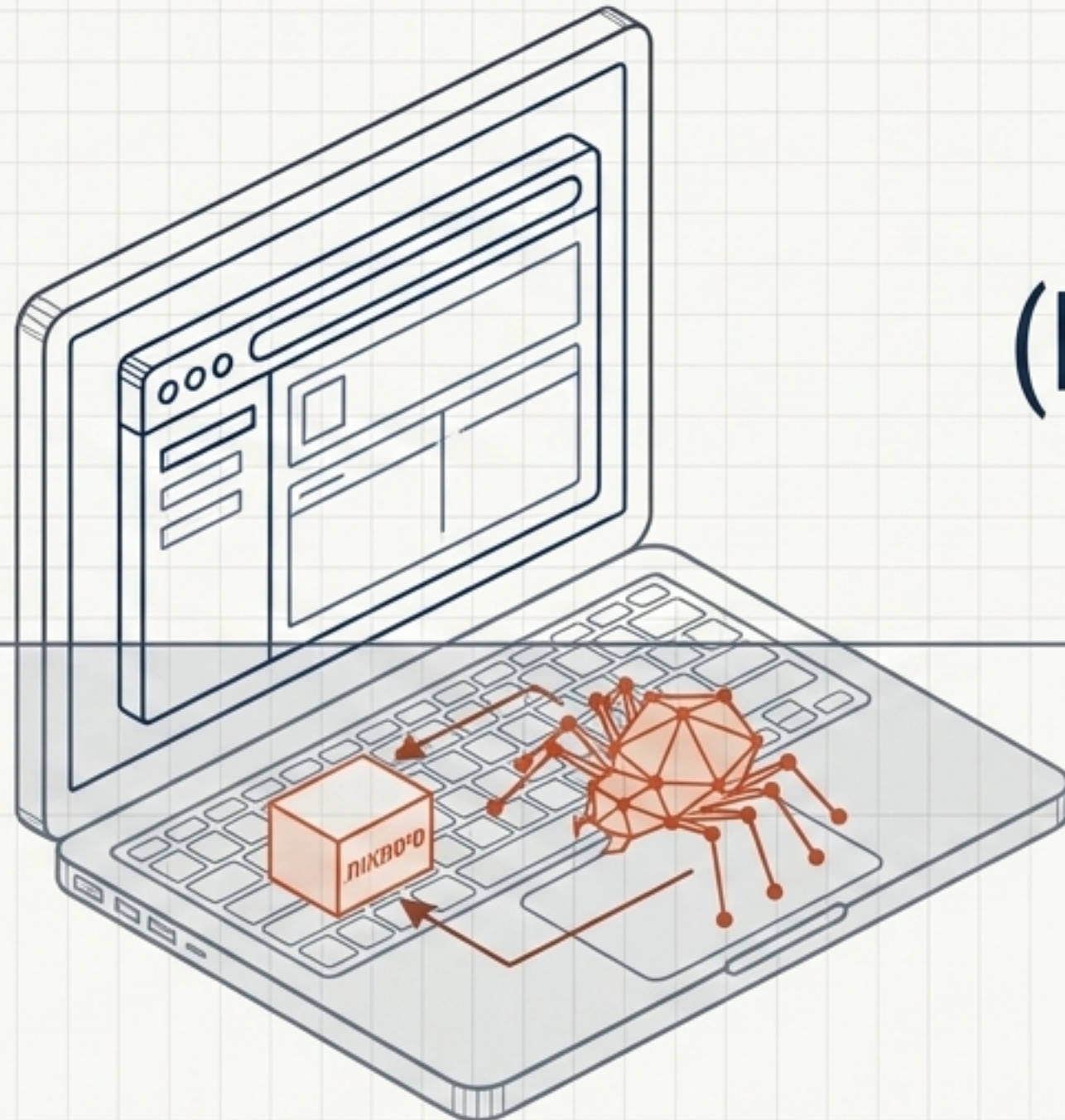
## פרוטוקול הגנה

חובה להשתמש בסיסמה ייחודית לכל אתר, ולהפעיל אימות דו-שלבי (2FA).



# וקטור 3: המערכת | תוכנות מזיקות (Malware)

surface layer  
wireframe



|                                                                                                                           |                                                                                                                  |                                                                                                                       |
|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <p>➔</p> <h2>מנגנון התקיפה</h2> <p>תוכנה שמתחזה ללגיטימית מותקנת במכשיר, וגונבת ברקע את מאגר הסיסמאות השמורות בדפדפן.</p> | <p>🎯</p> <h2>נקודת התורפה</h2> <p>הורדת אפליקציות ממקורות לא רשמיים והיעדר כלי הגנה אקטיביים על תחנת העבודה.</p> | <p>🛡️</p> <h2>פרוטוקול הגנה</h2> <p>הורדת תוכנות רק מחנויות רשמיות, ווידוא קיומו של אנטי-וירוס פעיל פעיל ומעודכן.</p> |
|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|

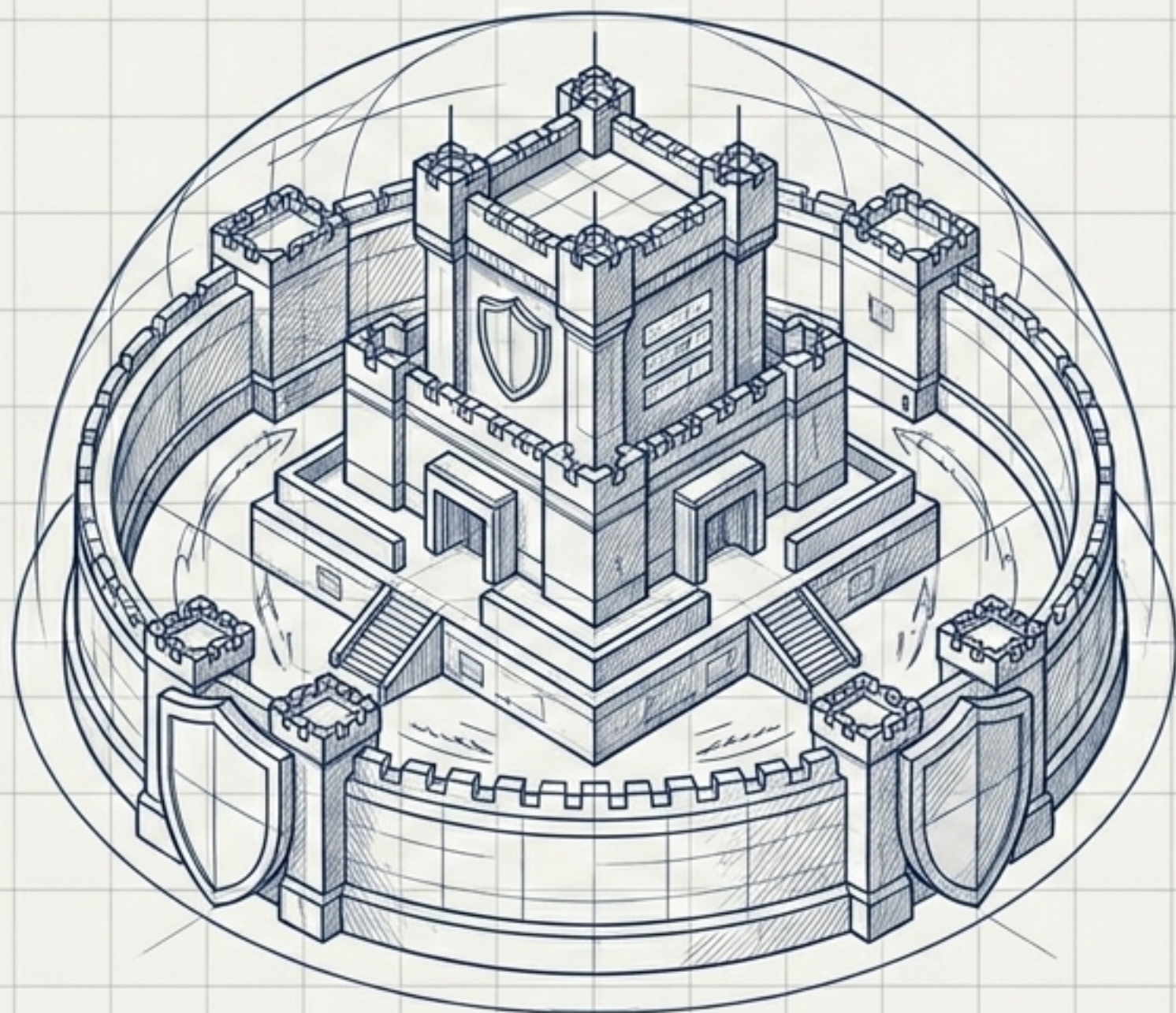


# מטריצת האיומים: השוואה ודיאגנוסטיקה

| כלי הגנה מרכזי                      | מאמץ התוקף       | וקטור         | סוג התקיפה         |
|-------------------------------------|------------------|---------------|--------------------|
| מודעות סביבתית                      | נמוך / פסיבי     | פיזי          | גלישת כתף          |
| הגדרות פרטיות                       | בינוני / אקטיבי  | אנושי / חברתי | איסוף מידע (OSINT) |
| אימות ישיר באפליקציה                | גבוה / פסיכולוגי | אנושי / חברתי | פישיונג            |
| מורכבות סיסמה                       | גבוה / אוטומטי   | טכנולוגי      | ניחוש אוטומטי      |
| אימות דו-שלבי (2FA) + סיסמה ייחודית | נמוך / אוטומטי   | טכנולוגי      | סיסמאות שדלפו      |
| אנטי-וירוס + חנויות רשמיות          | מוסווה           | טכנולוגי      | תוכנה מזיקה        |



# פרוטוקול ההגנה האולטימטיבי



|   |                                                                                                          |
|---|----------------------------------------------------------------------------------------------------------|
| ✓ | <b>גיוון וייחודיות</b><br>סיסמה ייחודית לכל פלטפורמה, מורכבת מאותיות ומספרים. ללא רצפים או פרטים אישיים. |
| ✓ | <b>שכבת מגן נוספת</b><br>הפעלת אימות דו-שלבי (2FA) בכל המערכות הקריטיות.                                 |
| ✓ | <b>אפס אמון בקישורים</b><br>התחברות לאתרים רק דרך הקלדה ישירה של הכתובת או דרך האפליקציה הרשמית.         |
| ✓ | <b>סביבה סטרילית</b><br>הימנעות מהקלדת סיסמאות במרחב הציבורי, והתקנת תוכנות מחנויות רשמיות בלבד.         |

שמירה על כללים אלו הופכת אותך מהחוליה החלשה - לקיר המגן של הארגון.